

Personal Data Protection Policy (Privacy Policy) V5.1

Document Control

Field	Details
Document Title	Personal Data Protection Policy (Privacy Policy)
Document ID	PDP-POL-001
Version	5.1
Effective Date	September 15, 2024
Review Date	September 15, 2025
Document Owner	Chief Privacy Officer (CPO)
Legal Basis	KSA Personal Data Protection Law (Royal Decree M/1)
Regulatory Authority	Saudi Data & AI Authority (SDAIA)
Total Pages	18 pages
Classification	PUBLIC (External-facing policy)
Language	English (Arabic version available: PDP-POL-001-AR)

Version History

Version	Date	Changes	Approved By
1.0	January 2022	Initial policy release	CPO
2.0	June 2022	Added GDPR adequacy clauses	CPO
3.0	January 2023	Updated consent management procedures	CPO
4.0	September 2023	Added biometric data provisions	CPO + Legal
5.0	March 2024	Major overhaul for NDMO Control 6.2 compliance	CPO + DPO
5.1	September 2024	Updated cross-border transfer mechanisms (GDPR SCC 2024)	CPO

Table of Contents

Company A is a Saudi Arabian government healthcare entity operating 47 clinics, 5 hospitals, and serving over 18.5 million patient records. We are deeply committed to protecting the privacy and personal data of our patients, employees, partners, and all individuals whose data we process.

This Personal Data Protection Policy establishes the framework for lawful, transparent, and secure processing of personal data in compliance with:

- KSA Personal Data Protection Law (PDPL) - Royal Decree M/19, dated 09/02/1443H
- NDMO (National Data Management Office) Compliance Framework - 191 controls across 15 domains
- NCA Essential Cybersecurity Controls (ECC) - Security controls 5-1-1 through 5-3-9
- ISO/IEC 27001:2022 - Information Security Management System
- ISO/IEC 27701:2019 - Privacy Information Management System

Key Highlights of This Policy:

- 7 Data Subject Rights are guaranteed and enforceable within specified timelines
- 6 Lawful Bases for processing personal data, with consent as the primary basis
- 24-hour response time for privacy inquiries and complaints
- 72-hour breach notification to SDAIA for high-risk incidents
- Zero data residency violations - sensitive data remains within KSA borders
- 100% encryption for personal data at rest (AES-256) and in transit (TLS 1.3)
- Annual privacy training mandatory for all 850 employees

This policy applies to all Company A employees, contractors, vendors, and third-party data processors. Non-compliance may result in disciplinary action up to termination, and penalties under PDPL (fines up to SAR 5 million).

2. INTRODUCTION

2.1 Purpose of This Policy

This policy serves three primary purposes:

1. Transparency: To inform data subjects (patients, employees, website visitors) about how their personal data is collected, used, stored, and protected.
2. Compliance: To ensure Company A operates in full compliance with KSA laws and international best practices.
3. Accountability: To establish clear roles, responsibilities, and procedures for privacy governance.

2.2 Commitment to Privacy

Company A recognizes that privacy is a fundamental right. We commit to:

- Processing personal data only for legitimate, lawful purposes

- Implementing robust technical and organizational security measures
- Providing transparent privacy notices at the point of data collection
- Respecting data subject rights and responding to requests promptly
- Conducting regular Privacy Impact Assessments (PIAs) for high-risk processing
- Training employees on privacy obligations and best practices

Our Privacy Promise: "We treat your data with the same care and confidentiality we expect for our own."

2.3 Regulatory Context

The Personal Data Protection Law (PDPL) came into force on March 23, 2023, establishing the first comprehensive data protection framework in Saudi Arabia. Key provisions include:

- Article 4: Consent must be "free, specific, informed, and unambiguous"
- Article 6: Data subject rights (access, rectification, erasure, portability)
- Article 26: Mandatory data breach notification within 72 hours
- Article 31: Cross-border transfer restrictions (data residency for sensitive categories)
- Article 39: Penalties up to SAR 5 million or 2% of annual revenue (whichever is higher)

Company A has designated a Chief Privacy Officer (CPO) - Fatima Al-Zahrani - as accountable executive, and a Data Protection Officer (DPO) - Dr. Khalid Al-Mansour - as operational lead.

3. SCOPE & APPLICABILITY

3.1 Who Is Covered by This Policy?

This policy applies to the following categories of data subjects:

Category	Description	Example Data Collected
Patients	Individuals receiving healthcare services	Name, National ID, medical records, billing info
Employees	Current, former, and prospective staff	HR records, payroll, performance reviews, biometri
Vendors & Contractors	Third-party service providers	Contact info, bank details (for payment)
Website Visitors	Users of www.companya.gov.sa	IP address, cookies, browsing behavior
Physical Visitors	Individuals entering Company A premises	CCTV footage, visitor logs
Research Participants	Individuals in clinical trials or studies	Informed consent, health data, genetic data (if ap

Total Data Subjects: Approximately 18.5 million patient records + 850 employees + 120 active vendors.

3.2 What Types of Personal Data Are Covered?

Personal data is categorized by sensitivity level under PDPL:

Tier 1: Basic Personal Data (Low Sensitivity)

- Name, email, phone number, postal address
- Job title, employer name
- IP address, device ID
- Non-sensitive communications (e.g., general inquiry emails)

Tier 2: Financial Data (Medium Sensitivity)

- Bank account number (IBAN)
- Credit card token (PCI-DSS compliant - we do NOT store full card numbers)
- Payment history, billing records
- Salary and payroll information (for employees)

Tier 3: Sensitive Personal Data (High Sensitivity - PDPL Article 5)

- Health Data: Medical diagnoses, prescriptions, lab results, surgical history
- Biometric Data: Fingerprint scans (for employee time & attendance)
- Genetic Data: DNA test results (if part of clinical trial)
- Criminal Records: Background check results (for security-sensitive roles only)
- Religious or Philosophical Beliefs: Dietary restrictions (e.g., halal meal requests)
- Racial or Ethnic Origin: Statistical reporting only (anonymized)

Special Rule for Tier 3 Data: Processing requires explicit consent + legitimate necessity (e.g., medical treatment, legal obligation). Tier 3 data is subject to stricter data residency rules (must remain within KSA).

3.3 Geographic Scope

- Primary Jurisdiction: Kingdom of Saudi Arabia
- Data Residency: All Tier 3 (Sensitive) data is stored exclusively in KSA-based data centers (AWS Middle East - Bahrain, Azure KSA Central)
- Cross-Border Transfers: Tier 1 and Tier 2 data may be transferred internationally only under approved mechanisms (see Section 9)

4. DEFINITIONS

Term	Definition
Personal Data	Any information relating to an identified or ident
Data Subject	The individual to whom the personal data relates.
Data Controller	The entity that determines the purposes and means

Data Processor	The entity that processes personal data on behalf
Processing	Any operation performed on personal data (collecti
Consent	A freely given, specific, informed, and unambiguou
Data Breach	A security incident resulting in accidental or unl
Anonymization	Irreversible process of removing identifiers so th
Pseudonymization	Reversible process of replacing identifiers with a
DPO	Data Protection Officer - the designated individua
CPO	Chief Privacy Officer - the executive accountable

5. KEY PRINCIPLES OF PERSONAL DATA PROCESSING

Company A adheres to the 7 Principles of Data Protection based on PDPL and international standards (GDPR Article 5, ISO 27701):

5.1 Lawfulness, Fairness & Transparency

Principle: Personal data must be processed lawfully, fairly, and in a transparent manner.

What This Means in Practice:

- We provide Privacy Notices at the point of data collection (e.g., patient registration form, job application)
- Privacy notices are written in clear, plain language (Arabic and English)
- We inform data subjects of: (1) What data we collect, (2) Why we collect it, (3) Who we share it with, (4) How long we keep it, (5) Their rights

Example: When a patient registers at a clinic, they receive a 2-page Privacy Notice explaining that we collect their medical history to provide treatment, and that data is shared with the treating physician and billing department only.

5.2 Purpose Limitation

Principle: Personal data must be collected for specified, explicit, and legitimate purposes, and not processed in a manner incompatible with those purposes.

What This Means in Practice:

- Every data collection has a documented Purpose Statement (e.g., "Marketing Campaign X," "Employee Payroll," "Clinical Trial Y")
- Data collected for one purpose cannot be reused for a secondary purpose without new consent or legal justification

Example - Violation Prevented:

- ■ WRONG: Phone numbers collected for "Two-Factor Authentication (2FA)" are used to send "Marketing SMS"

- ■ CORRECT: Phone numbers for 2FA are used only for security. Marketing SMS requires separate opt-in consent.

5.3 Data Minimization

Principle: Personal data must be adequate, relevant, and limited to what is necessary for the purposes for which it is processed.

What This Means in Practice:

- We ask for the minimum data required to fulfill the purpose
- Forms and systems are reviewed annually to remove unnecessary fields

Example - Data Minimization Applied:

- Scenario: Patient booking a parking space at hospital
- ■ Necessary: Name, Phone (for booking confirmation)
- ■ Unnecessary: Marital Status, Mother's Maiden Name, Blood Type

5.4 Accuracy

Principle: Personal data must be accurate and kept up to date. Inaccurate data must be erased or rectified without delay.

What This Means in Practice:

- We implement data validation rules (e.g., IBAN checksum, National ID format validation)
- Data subjects can update their information via Self-Service Portal or by submitting a Data Subject Request Form

Example: If a patient's phone number changes, they can log into the Patient Portal and update it immediately, triggering a real-time update across all connected systems.

5.5 Storage Limitation

Principle: Personal data must be kept only for as long as necessary for the purposes for which it is processed.

What This Means in Practice:

- We maintain a Data Retention Schedule (see Policy DOP-POL-002: Data Retention & Disposal Policy)
- Data is automatically deleted or anonymized after the retention period expires

Example Retention Periods:

- Medical Records: 10 years after last treatment (per KSA Ministry of Health regulation)
- Employee Payroll: 11 years (per Zakat, Tax & Customs Authority requirement)
- CCTV Footage: 90 days (then auto-deleted unless needed for investigation)
- Website Cookies: 13 months (per NCA ECC 5-2-6)

5.6 Integrity & Confidentiality (Security)

Principle: Personal data must be processed in a manner that ensures appropriate security, including protection against unauthorized or unlawful processing, accidental loss, destruction, or damage.

What This Means in Practice:

- Encryption: All personal data is encrypted at rest (AES-256) and in transit (TLS 1.3)
- Access Control: Role-Based Access Control (RBAC) with Least Privilege principle
- Multi-Factor Authentication (MFA): Required for all systems processing Tier 2 or Tier 3 data
- Security Monitoring: 24/7 Security Operations Center (SOC) with SIEM (Splunk)

Example: A nurse accessing a patient's medical record via Epic EHR must authenticate with (1) Username/Password + (2) SMS OTP. All access is logged and monitored.

5.7 Accountability

Principle: The data controller is responsible for demonstrating compliance with all principles.

What This Means in Practice:

- We maintain Records of Processing Activities (ROPA) documenting all personal data processing
- We conduct annual privacy audits (internal and external)
- We perform Privacy Impact Assessments (PIAs) for high-risk processing (e.g., new AI system, biometric authentication)
- We document all data breaches in a Security Incident Register

Example: Before deploying a new Patient Portal with facial recognition login (biometric), we conducted a PIA (Report ID: PIA-2024-07) which identified 8 privacy risks and implemented 8 mitigations (e.g., local processing of biometric data, no cloud storage of facial templates).

6. LAWFUL BASIS FOR PROCESSING

Under PDPL, personal data may only be processed if at least one of the following lawful bases applies:

Lawful Basis	Description	Example at Company A
1. Consent	Data subject has given clear, affirmative consent	Patient opts in to receive health tips via SMS
2. Contractual Necessity	Processing is necessary for performing a contract	Employee payroll processing (employment contract)
3. Legal Obligation	Required to comply with a law or regulation	Reporting communicable diseases to Ministry of Health
4. Vital Interests	Necessary to protect life or health	Emergency treatment for unconscious patient
5. Public Interest	Necessary for public health or safety	COVID-19 vaccination tracking
6. Legitimate Interest	Necessary for legitimate business interests (balanced against individual rights)	Fraud detection on patient billing

Primary Lawful Basis at Company A: Consent (for non-essential processing) and Contractual Necessity (for essential services).

7. DATA SUBJECT RIGHTS

Under PDPL Article 6, every data subject has the following 7 fundamental rights:

7.1 Right to Information

What It Means: You have the right to know what personal data we hold about you, why we are processing it, and who we share it with.

How We Fulfill This Right: We provide Privacy Notices at the point of data collection (e.g., patient registration, job application).

7.2 Right to Access

What It Means: You have the right to request a copy of your personal data in a commonly used format (PDF, CSV, Excel).

How to Exercise: Submit a Data Subject Access Request (DSAR) via:

- Email: `privacy@companya.gov.sa``
- Online Form: `www.companya.gov.sa/privacy/dsar``
- In-Person: Privacy Office (Building A, Floor 2, Riyadh Main Campus)

Response Time: 30 calendar days from receipt of request (may extend by 60 days if complex)

Example Output: You will receive a PDF report containing all your records (e.g., medical history, appointment logs, billing statements) with sensitive data of other individuals redacted.

7.3 Right to Rectification

What It Means: You have the right to correct inaccurate or incomplete personal data.

How to Exercise:

- Self-Service: Log into Patient Portal and update your profile
- Assisted: Submit rectification request via `privacy@companya.gov.sa``

Response Time: Immediate (for self-service) or 5 business days (for assisted)

Example: If your medical record shows wrong blood type (O+ instead of A+), you can request correction with supporting documentation (lab report).

7.4 Right to Erasure (Right to be Forgotten)

What It Means: You have the right to request deletion of your personal data under certain conditions.

When This Right Applies:

- The data is no longer necessary for the original purpose
- You withdraw consent and there is no other lawful basis
- The data was unlawfully processed
- Deletion is required by law

When This Right DOES NOT Apply:

- Legal obligation requires retention (e.g., tax records must be kept 11 years)
- Medical records needed for your ongoing treatment
- Legal claims or disputes are pending
- Public interest requires retention (e.g., epidemiological research)

Response Time: 15 business days (we will confirm whether erasure is possible under law)

Example - Request Granted: Former employee requests deletion of recruitment interview notes after 5 years. APPROVED (no legal retention requirement).

Example - Request Denied: Patient requests deletion of surgery records from 2 years ago. DENIED (Ministry of Health requires 10-year retention for medical records).

7.5 Right to Object to Processing

What It Means: You have the right to object to processing based on "legitimate interests" (Lawful Basis #6).

How to Exercise: Email privacy@companya.gov.sa with subject line "Objection to Processing"

Example: We use your email for fraud detection (legitimate interest). You object because you believe it's intrusive. We assess the objection and may (1) stop processing, (2) provide compelling justification to continue.

7.6 Right to Data Portability

What It Means: You have the right to receive your personal data in a structured, commonly used, machine-readable format (e.g., JSON, CSV, XML) and transmit it to another controller.

When This Right Applies: Only when processing is based on consent or contract and is carried out by automated means.

How to Exercise: Submit portability request via privacy@companya.gov.sa

Response Time: 30 calendar days

Example: You switch to a different healthcare provider. You request your medical records in HL7 FHIR format to import into the new provider's system.

7.7 How to Exercise Your Rights

Step-by-Step Process:

1. Submit Request: Use one of the following methods:

- Email: `privacy@companya.gov.sa` (attach completed DSAR form from Appendix A)
- Online Portal: `www.companya.gov.sa/privacy/dsar`
- In-Person: Privacy Office (Riyadh Main Campus, Building A, Floor 2, Office 201)
- Mail: Company A - Privacy Office, PO Box 12345, Riyadh 11564, KSA

2. Identity Verification: We will verify your identity using one of:

- National ID number (last 4 digits + full name + date of birth)
- Absher Digital ID (scan QR code)
- In-person visit with valid ID

3. Processing: Our Privacy Team reviews your request within 5 business days

4. Response: We respond within 30 calendar days (or notify you of extension)

No Fee: Exercising your rights is free of charge (unless requests are manifestly unfounded or excessive).

8. CONSENT MANAGEMENT

8.1 Requirements for Valid Consent (PDPL Article 4)

Consent must be:

- Freely Given: Not coerced or bundled with acceptance of terms
- Specific: Clear about what data and for what purpose
- Informed: Data subject knows what they are consenting to
- Unambiguous: Affirmative action (e.g., checkbox, digital signature)

Invalid Consent Examples:

- Pre-ticked checkboxes
- Silence or inactivity
- Bundled consent ("Accept all or no service")

8.2 Consent Mechanisms at Company A

Context	Mechanism	Record Retention
Website Cookies	Cookie banner with "Accept" / "Reject" buttons	3 years
Marketing SMS	Opt-in checkbox on patient registration form	Lifetime (until withdrawal)
Clinical Research	Written informed consent form (signed)	10 years (per Good Clinical Practice)

Employee Biometric	Digital signature on HR onboarding form	11 years (employment record)
--------------------	---	------------------------------

8.3 Right to Withdraw Consent

Data subjects can withdraw consent at any time by:

- Clicking "Unsubscribe" link in marketing emails
- Submitting Consent Withdrawal Form (Appendix B) via email
- Updating preferences in Patient Portal

Effect of Withdrawal: Processing based on that consent will stop immediately (but does not affect lawfulness of processing before withdrawal).

9. INTERNATIONAL DATA TRANSFERS

9.1 General Principle (Data Residency)

Under PDPL Article 31, the following data categories MUST remain within KSA:

- Sovereign Data: Government records, national security data
- Tier 3 Sensitive Personal Data: Health data, biometric data, genetic data

Company A Compliance: All patient medical records and employee biometric data (fingerprints) are stored exclusively in AWS Middle East (Bahrain) and Azure KSA Central data centers.

9.2 Exceptions (When Data May Leave KSA)

Data may be transferred outside KSA if:

Exception 1: Adequacy Decision

SDAIA has approved the destination country as providing adequate protection (similar to GDPR adequacy).
Current Status: As of September 2024, no adequacy decisions have been issued by SDAIA.

Exception 2: Standard Contractual Clauses (SCCs)

Company A has signed SDAIA-approved SCCs with cloud providers and international vendors.
Example: Our contract with Microsoft Azure (Ireland data center) for non-sensitive HR data backup includes SCC Module 2 (Controller-to-Processor).

Exception 3: International Treaty Obligation

Transfer is necessary for international treaty or convention.
Example: Sharing patient data with WHO for epidemiological research (COVID-19 surveillance).

Exception 4: Explicit Consent

Data subject provides explicit consent for the specific transfer.
Example: Patient traveling abroad requests medical records to be sent to foreign hospital.

9.3 Active Cross-Border Transfers (2024)

Vendor	Data Transferred	Destination	Mechanism	Volume
Microsoft Azure	Non-sensitive HR records backup	Ireland (EU)	SCCs	1.2 TB
Oracle Cloud EBS	Financial transaction logs	USA (Ashburn)	SCCs	850 GB
Salesforce	Marketing CRM data (Tier 1 only)	USA (AWS us-east-1)	SCCs	45 GB

Zero Transfers of Tier 3 Data: No sensitive personal data has been transferred outside KSA in 2024.

10. DATA SECURITY MEASURES

Company A implements defense-in-depth security aligned with NCA ECC and ISO 27001:

10.1 Technical Measures

Security Control	Implementation	Compliance Reference
Encryption at Rest	AES-256-GCM for all databases	NCA ECC 5-1-4
Encryption in Transit	TLS 1.3 (min) for all APIs and web traffic	NCA ECC 5-1-5
Multi-Factor Authentication	Microsoft Authenticator (TOTP) for all employees	NCA ECC 5-2-1
Privileged Access Management	CyberArk PAM for database admin access	NCA ECC 5-2-3
Endpoint Protection	CrowdStrike Falcon EDR on 100% of devices	NCA ECC 5-3-2
Data Loss Prevention	Microsoft Purview DLP (blocks email of Tier 3 data)	NCA ECC 5-3-5
Security Monitoring	Splunk SIEM with 24/7 SOC	NCA ECC 5-3-9

10.2 Organizational Measures

- Privacy by Design: Privacy Impact Assessments (PIAs) mandatory for all new systems
- Staff Training: Annual privacy training (2 hours online + exam, 95% pass rate required)
- Vendor Due Diligence: Security questionnaire + contract review for all data processors
- Incident Response Plan: Documented procedure for data breach response (tested quarterly)

- Access Reviews: Quarterly recertification of user access rights

10.3 Physical Security

- Data Center: Tier III certified (99.982% uptime SLA)
- Access Control: Biometric (fingerprint) + badge for entry to server rooms
- CCTV: 24/7 surveillance with 90-day retention
- Disaster Recovery: Geographic redundancy (Riyadh primary, Jeddah secondary)

11. DATA BREACH NOTIFICATION

11.1 Definition of a Personal Data Breach

A breach is any security incident resulting in:

- Unauthorized access to personal data
- Accidental loss or destruction
- Alteration or unauthorized disclosure

Examples of Breaches:

- Ransomware encrypting patient database
- Employee emailing patient list to wrong recipient
- Lost laptop containing unencrypted employee records
- Hacker accessing patient portal accounts

11.2 Notification to SDAIA (Regulatory Authority)

Under PDPL Article 26, Company A must notify SDAIA of breaches that pose high risk to data subjects within 72 hours of becoming aware.

Notification Must Include:

1. Nature of the breach (what happened, when, how)
2. Categories and approximate number of affected data subjects
3. Contact details of our DPO
4. Likely consequences of the breach
5. Measures taken or proposed to address the breach

Communication Method: Email to breaches@sdaia.gov.sa + online portal submission

11.3 Notification to Data Subjects

We must notify affected individuals without undue delay if the breach is likely to result in high risk to their rights and freedoms.

Notification Includes:

- Description of the breach in plain language
- Contact details of our DPO
- Likely consequences
- Measures taken to mitigate harm
- Recommended actions (e.g., "Change your password," "Monitor bank statements")

Example Notification (SMS):

> "Company A Security Alert: We detected unauthorized access to your account on Dec 15. No medical data was accessed. Please reset your password immediately via Patient Portal. Questions? Call 800-123-4567."

12. COOKIES & ONLINE TRACKING TECHNOLOGIES

12.1 What Are Cookies?

Cookies are small text files placed on your device when you visit our website (www.companya.gov.sa).

12.2 Types of Cookies We Use

Cookie Type	Purpose	Consent Required?	Retention Period
Necessary (Functional)	Session management, security (CSRF tokens)	No (exempted)	Session (deleted on browser close)
Analytics	Google Analytics (traffic statistics, page views)	Yes	13 months
Marketing	Facebook Pixel, LinkedIn Insight Tag (ad targeting)	Yes	13 months

12.3 Cookie Consent Banner

When you first visit our website, you will see a cookie banner with three options:

1. Accept All: Consent to all cookies (necessary + analytics + marketing)
2. Reject Non-Essential: Only necessary cookies (analytics and marketing disabled)
3. Customize: Granular control (choose which categories to allow)

Consent Record: Your choice is stored in a first-party cookie (cookie_consent) valid for 12 months. You can change preferences anytime via the website footer link "Cookie Settings."

12.4 Third-Party Cookies

We use the following third-party services:

- Google Analytics: Tracks website usage (anonymized IP addresses)
- Facebook Pixel: Measures ad campaign effectiveness
- Hotjar: Records heatmaps and session replays (with IP anonymization)

No Sale of Data: We do NOT sell your personal data to third parties for their own marketing.

13. CHILDREN'S PRIVACY

13.1 Age Threshold

Under PDPL, individuals under 18 years old are considered minors.

13.2 Parental Consent Requirement

We require verifiable parental consent before collecting personal data from minors for:

- Online account creation (Patient Portal)
- Marketing communications
- Non-essential services (e.g., health tips newsletter)

Exemption: Parental consent is NOT required for medical treatment (covered under "vital interests" lawful basis).

13.3 Verification Method

For online services, we verify parental consent via:

- Absher Family Account: Parent logs in and authorizes child's account
- Signed Consent Form: Uploaded via portal or submitted in-person

Example: A 16-year-old patient wants to create a Patient Portal account. The system requires their parent to authenticate via Absher and approve the registration.

14. COMPLAINTS & DISPUTE RESOLUTION

14.1 Internal Complaint Process

If you believe we have violated your privacy rights, you may file a complaint:

Contact:

- Email: privacy@companya.gov.sa
- Phone: 800-123-4567 (toll-free, Arabic & English support)
- In-Person: Privacy Office (Riyadh Main Campus, Building A, Floor 2, Office 201)
- Mail: Company A - Privacy Office, PO Box 12345, Riyadh 11564, KSA

SLA:

- Acknowledgment: Within 24 hours (email confirmation with ticket number)
- Investigation: Completed within 7 business days
- Resolution: Final response within 15 business days (may extend to 30 days if complex)

14.2 Escalation to SDAIA

If you are unsatisfied with our response, you have the right to lodge a complaint with the regulatory authority:

Saudi Data & AI Authority (SDAIA) - Personal Data Protection Committee

- Website: www.sdaia.gov.sa
- Email: complaints@sdaia.gov.sa
- Phone: 19993 (SDAIA Unified Number)

SDAIA's Powers: SDAIA can investigate complaints, issue binding orders, and impose fines up to SAR 5 million for PDPL violations.

15. POLICY REVIEW & UPDATES

15.1 Review Frequency

This policy is reviewed annually (every September) and updated as needed to reflect:

- Changes in Saudi laws or regulations
- New technologies or processing activities
- Findings from privacy audits or PIAs
- Feedback from data subjects or regulators

Last Review: September 15, 2024

Next Scheduled Review: September 15, 2025

15.2 Notification of Changes

If we make material changes to this policy (e.g., new data processing purposes, new third parties), we will:

- Post the updated policy on our website with a "Last Updated" date
- Notify registered patients and employees via email (30 days before effective date)

- For significant changes affecting data subject rights, obtain renewed consent where required

Version Control: All previous versions are archived and available upon request.

16. CONTACT INFORMATION

16.1 Chief Privacy Officer (CPO)

Name: Fatima Al-Zahrani

Title: Chief Privacy Officer

Email: fatima.alzahrani@companya.gov.sa

Phone: +966-11-555-1001

16.2 Data Protection Officer (DPO)

Name: Dr. Khalid Al-Mansour

Title: Data Protection Officer

Certifications: CIPP/E (Certified Information Privacy Professional), CIPM (Certified Information Privacy Manager)

Email: dpo@companya.gov.sa

Phone: +966-11-555-1002

16.3 Privacy Office (General Inquiries)

Email: privacy@companya.gov.sa

Toll-Free Hotline: 800-123-4567 (available 24/7, Arabic & English)

Office Hours: Sunday - Thursday, 8:00 AM - 4:00 PM (Saudi Arabia Time)

Postal Address: Company A - Privacy Office, Building A, Floor 2, Office 201, PO Box 12345, Riyadh 11564, Kingdom of Saudi Arabia

APPENDIX A: DATA SUBJECT REQUEST FORM

To be completed by data subject and submitted to privacy@companya.gov.sa

REQUEST TYPE (Check one):

☐ Access (obtain copy of my data)

☐ Rectification (correct inaccurate data)

- ☐ Erasure (delete my data)
- ☐ Objection (stop processing my data)
- ☐ Portability (receive data in machine-readable format)
- ☐ Other: _____

YOUR INFORMATION:

Full Name: _____

National ID / Iqama Number: _____

Date of Birth: ____ / ____ / ____

Email Address: _____

Phone Number: _____

Relationship to Company A: ☐ Patient ☐ Employee ☐ Vendor ☐ Website User ☐ Other: _____

DETAILS OF REQUEST:

Please describe your request in detail (e.g., which data you want to access, what needs to be corrected, reason for deletion):

IDENTITY VERIFICATION:

To protect your privacy, we require identity verification. Please provide ONE of the following:

- ☐ Attach copy of National ID / Iqama (both sides)
- ☐ Visit our office in-person with valid ID
- ☐ Absher Digital ID verification (QR code will be sent to your email)

SIGNATURE:

I certify that the information provided is accurate and that I am the data subject or authorized representative.

Signature: _____

Date: ____ / ____ / ____

FOR OFFICIAL USE ONLY:

Request ID: _____

Received Date: ____ / ____ / ____

Assigned To: _____

Status: ☐ Under Review ☐ Approved ☐ Denied ☐ Completed

APPENDIX B: CONSENT WITHDRAWAL FORM

To withdraw consent for marketing communications or other non-essential processing

YOUR INFORMATION:

Full Name: _____

Email Address: _____

Phone Number: _____

CONSENT TO WITHDRAW (Check all that apply):

- ☐ Marketing SMS messages
- ☐ Marketing emails
- ☐ Marketing phone calls
- ☐ Analytics cookies on website
- ☐ Marketing cookies on website
- ☐ Sharing data with third-party partners for marketing
- ☐ Other: _____

EFFECTIVE DATE:

- ☐ Immediately (stop all communications now)
- ☐ Specific Date: ____ / ____ / ____

ACKNOWLEDGMENT:

I understand that withdrawing consent will not affect the lawfulness of processing before withdrawal. I also understand that withdrawing consent for essential services (e.g., medical treatment communications) may impact my ability to receive services.

Signature: _____

Date: ____ / ____ / ____

SUBMISSION: Email completed form to privacy@companya.gov.sa or click "Unsubscribe" link in any marketing email.

APPENDIX C: GLOSSARY OF TERMS

(For terms not defined in Section 4, see below)

Term	Definition
Absher	Saudi government digital platform for identity ver
Adequacy Decision	Regulatory determination that a foreign country pr
CCTV	Closed-Circuit Television (video surveillance)
CSRF Token	Security token to prevent Cross-Site Request Forge
DLP	Data Loss Prevention (technology to prevent data l
DSAR	Data Subject Access Request (formal request to acc
EDR	Endpoint Detection and Response (cybersecurity too
FHIR	Fast Healthcare Interoperability Resources (health
GDPR	General Data Protection Regulation (EU privacy law
HL7	Health Level 7 (healthcare messaging standard)
KSA	Kingdom of Saudi Arabia
NCA	National Cybersecurity Authority (Saudi regulatory
NDMO	National Data Management Office (Saudi regulatory
OTP	One-Time Password (used for two-factor authenticat
PAM	Privileged Access Management (security control for
PCI-DSS	Payment Card Industry Data Security Standard
PDPL	Personal Data Protection Law (KSA Royal Decree M/1
PIA	Privacy Impact Assessment (risk assessment for pri
ROPA	Record of Processing Activities (GDPR/PDPL complia
SCC	Standard Contractual Clauses (legal mechanism for
SDAIA	Saudi Data & AI Authority (regulatory authority fo
SIEM	Security Information and Event Management (cyberse
TLS	Transport Layer Security (encryption protocol for
TOTP	Time-Based One-Time Password (MFA method)

END OF POLICY

Document Approval:

Role	Name	Signature	Date
------	------	-----------	------

Chief Privacy Officer (CPO)	Fatima Al-Zahrani	[Digitally Signed]	September 15, 2024
Data Protection Officer (DPO)	Dr. Khalid Al-Mansour	[Digitally Signed]	September 15, 2024
Legal Counsel	Ahmed Al-Rashid	[Digitally Signed]	September 15, 2024
Chief Information Security Officer (CISO)	Mohammed Al-Qahtani	[Digitally Signed]	September 15, 2024

Official Seal: Company A - Riyadh, Kingdom of Saudi Arabia

Distribution:

- All Company A Employees (via email + intranet posting)
- Public website: `www.companya.gov.sa/privacy-policy`
- Patient Portal: Displayed upon registration
- Vendor Portal: Included in Data Processing Agreements (DPAs)

Related Policies:

- DOP-POL-002: Data Retention & Disposal Policy
- SEC-POL-003: Access Control Policy
- SEC-POL-005: Data Security Strategy
- PDP-PROC-001: Data Breach Notification Procedure
- PDP-PROC-002: Consent Management Procedures